

MÓDULO 8: SEGURIDAD

LOGGING AND MONITORING FAILURES

OWASP TOP 10

BIG school

GENERAMOS
NEGOCIO

BIGSEO



Security Logging and Monitoring Failures

Índice

- Introducción: la ceguera de las aplicaciones
- ¿Qué significa Logging y Monitoring?
- ¿Por qué ocurre esta vulnerabilidad?
- Ejemplos reales de fallos de logging
- ¿Qué puede hacer un atacante si no hay logging ni monitoreo?
- ¿Cómo detectar fallos de logging y monitoreo?
- ¿Cómo prevenir y fortalecer el logging y monitoreo?
- Conclusiones



Security Logging and Monitoring Failures

BIG school

BIGSEIO

GENERAMOS
NEGOCIO

Introducción: la ceguera de las aplicaciones

- Muchas aplicaciones no fallan por ser vulnerables, sino por no detectar que fueron atacadas.
- Si no registras ni monitoreas eventos, es como tener cámaras apagadas durante un robo.
- Esta falla ocurre cuando el sistema no registra los eventos críticos o no tiene alertas activas.
- Sin ambos, no existe visibilidad ni capacidad de respuesta ante un ataque.

¿Qué significa Logging y Monitoring?

Logging: registrar eventos relevantes (intentos de login, cambios de usuarios, accesos, errores).

Monitoring: analizar los registros en tiempo real para detectar anomalías.

Logging sin monitoreo: escribir un diario y nunca leerlo.

Monitoring sin logging: intentar adivinar sin evidencia.

La combinación de ambos permite detectar, responder y aprender de los incidentes.

Las alertas automáticas son clave: fallos masivos de login, cambios en permisos, subidas extrañas.

¿Por qué ocurre esta vulnerabilidad?

- No se considera parte de la seguridad, sino del “debugging”.
- Falta definir qué eventos son críticos para registrar.
- Logs almacenados localmente, sin protección ni revisión periódica.
- Ausencia de alertas y monitoreo activo.

Resultado: incidentes detectados tarde o nunca, sin datos para investigar.

Ejemplos reales de fallos de logging

- API sin registro de intentos fallidos: permite ataques de fuerza bruta sin detección.
- Eliminación automática de logs: sin historial, imposible investigar incidentes.
- Logs incompletos: mensajes genéricos como "Error 500" sin contexto útil.
- Logs manipulables: guardados en texto plano, un atacante puede borrarlos o editarlos.
- Sin alertas activas: ataques solo se descubren cuando ya causaron daño.

¿Qué puede hacer un atacante si no hay logging ni monitoreo?

Moverse por el sistema sin dejar rastros.

Escalar privilegios o acceder a información sin ser detectado.

Borrar evidencia después del ataque.

A nivel legal y operativo:

- No hay trazabilidad del incidente.
- Incumplimiento de normativas (GDPR, ISO 27001, NIST).
- Pérdida de reputación por descubrir ataques tardíamente.

¿Cómo detectar fallos de logging y monitoreo?

- **Auditoría de logs:** revisar qué eventos se registran, su nivel de detalle y retención.
- **Uso de SIEM:** herramientas como Splunk, Wazuh, Graylog o ELK centralizan y correlacionan eventos.
- **Verificar tras pentesting:** comprobar si los ataques simulados quedaron en los registros.
- **Simular incidentes:** medir velocidad de detección y efectividad de alertas.
- **Revisar permisos:** los logs no deben ser editables por usuarios sin privilegios

¿Cómo prevenir y fortalecer el logging y monitoreo?

1. Diseñar el logging desde el inicio: definir qué eventos son críticos.
2. Autenticación, accesos, cambios de roles, errores y APIs sensibles.
3. Agregar contexto útil: incluir usuario, hora, IP, acción y resultado.
4. Centralizar y proteger: usar servidores o herramientas SIEM con almacenamiento seguro y cifrado.
5. Monitoreo activo: configurar alertas automáticas en tiempo real ante patrones anómalos.
6. Múltiples fallos de login, accesos fuera de horario, cambios en configuración.
7. Definir retención e integridad: conservar logs por el tiempo exigido y protegerlos con hashes o firmas.
8. Formar al equipo: devs y ops deben entender cómo generar logs útiles y responder ante alertas.

Conclusiones

1. No puedes proteger lo que no ves.
2. El logging y monitoreo son los ojos de la seguridad de tu aplicación.
3. Un registro bien hecho puede descubrir ataques antes de que causen daño.
4. Los mejores equipos son los que detectan rápido, analizan y aprenden.
5. Pregúntate siempre: "¿Podría detectar si alguien abusa de esto ahora mismo?" si no, tu próxima tarea es mejorar la visibilidad y el monitoreo.
6. Ver y entender lo que pasa es el primer paso hacia una defensa efectiva.